

Plan de traitement, risque résiduel (D7) et Note de stratégie

Le registre est rempli, les résiduels sont cotés, l'outil ne signale plus d'incohérence. Il reste le travail que l'outil ne fait pas : transformer un registre en décision présentable. Un comité de direction, le COMEX, ne lit pas un registre, il lit un plan, et la différence entre les deux est tout le sujet de cette dernière séquence. À la fin, le dossier D7 sera constitué, avec la version de la note de stratégie qui porte le traitement du risque.

Objectifs de la séance

À l'issue de ce TP :

- **Assembler** le dossier D7 avec ses quatre exigences d'acceptation, et vérifier chacune avant de rendre
- **Rédiger** une décision de traitement lisible par un tiers dans deux ans, sans son auteur pour l'expliquer
- **Formaliser** une acceptation, y compris dérogatoire, avec les cinq éléments qui la rendent opposable
- **Présenter** un plan de traitement à une direction, en séparant ce qui se décide de ce qui s'exécute
- **Enrichir** la note de stratégie de sa sous-section de traitement, sans réécrire les précédentes

Prérequis

- Le registre de risques complété au TP précédent, avec cotations, options, responsables, échéances et résiduels.
- L'échelle et l'appétence de la séance 5, et la ligne d'acceptation discutée ce matin au TD.
- La note de stratégie dans son état de la séance 6.

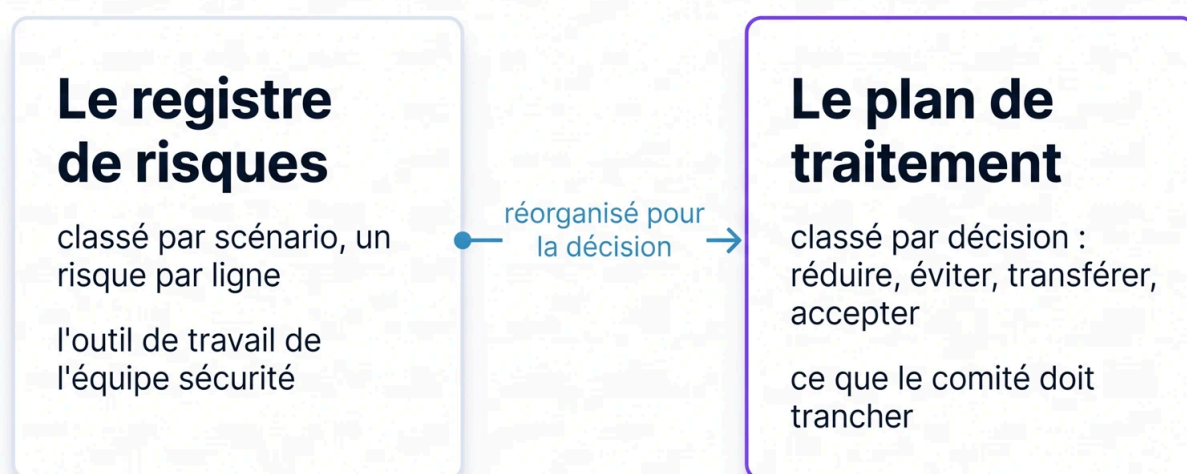
Ce que le dossier D7 doit contenir, et comment il sera lu

Le livrable de la séance porte quatre exigences d'acceptation, et elles seront vérifiées une par une. **Aucun risque du registre sans décision. Tout résiduel qui dépasse l'appétence posée en séance 5 porte une dérogation motivée. Les cotations sont cohérentes avec les échelles du D5, jamais recrées.** Et chaque risque porte son option, ses mesures, son responsable, son échéance et son résiduel coté.

Ces quatre exigences ne sont pas des formalités administratives, chacune ferme une porte que la pratique laisse ouverte. La première ferme la porte du risque orphelin, celui qu'on a identifié, coté, puis laissé sans suite parce que la réunion s'est terminée. La deuxième ferme celle de l'acceptation implicite, où un résiduel inacceptable se retrouve porté par personne. La troisième ferme celle de la cotation opportuniste, qui change d'échelle quand le résultat déplaît.

Une remarque sur la lecture. Le dossier sera lu deux fois : par un correcteur après la séance, et par son auteur en séance 10 quand un membre du comité demandera de justifier une ligne. Écrire pour la seconde lecture.

Étape 1 : construire le plan de traitement (25 minutes)



Consignes

Extraire le registre et le réorganiser en plan de traitement, par décision et non par scénario, ce qui se réduit, ce qui s'évite, ce qui se transfère, ce qui s'accepte : un comité arbitre des décisions, pas des scénarios. Chaque ligne de réduction est complète, risque visé, mesure, porteur nommé, échéance, charge estimée et effet attendu sur la cotation, qui justifie le résiduel. Les mesures qui traitent plusieurs risques à la fois se regroupent : ce sont les meilleures. Séparer visiblement ce qui relève d'une décision de direction, engager un budget, renoncer à une activité, accepter un risque, de ce qui relève de l'exécution. La charge se saisit dans l'outil, sur chaque mesure appliquée, section « Coût » : pour la construction, le build, le « Coût fixe » en euros et les « Jours-personnes nécessaires pour la mise en œuvre » ; pour le fonctionnement, le run, le « Coût fixe » annuel et les « Jours-personnes nécessaires annuellement » ; puis la « Durée d'amortissement (années) » du build. Là où le dossier ne donne rien, un coût fixe à zéro et les jours-personnes estimés suffisent, en le disant. L'outil convertit les jours au taux journalier de l'instance, 500 euros par défaut dans « Paramètres », onglet « Général », section « Paramètres financiers », à laisser tel quel ce jour, et calcule le coût annuel de chaque mesure : build divisé par la durée

d'amortissement, plus run. Le plan reporte pour chaque mesure ses jours-personnes et son coût annuel, en distinguant le build, une dépense d'investissement (CAPEX, capital expenditure), du run, une dépense de fonctionnement (OPEX, operational expenditure) ; l'onglet « Plan d'action » de l'analyse en donne le total dans son aperçu budgétaire. Ce total se met en face de la fourchette du coût de l'inaction du matin : c'est l'arbitrage promis au Directeur Financier, un coût certain contre une perte plausible. Le TP facultatif de la séance 11 ira plus loin, décaissement, perte attendue, retour sur investissement.

À produire : le plan de traitement du groupe sur le gabarit ci-dessous, priorisé sur trois ans, chaque mesure avec ses jours-personnes et son coût annuel lus dans l'outil, build et run distingués, et son effet attendu, les décisions de direction distinguées de l'exécution, et le coût annuel total du plan, lu dans l'aperçu budgétaire, mis en face de la fourchette du coût de l'inaction du matin.

Décision et risque visé	Mesure	Porteur et échéance	Coût (build, run, amortissement, annuel)	Effet sur la cotation
Réduire (exemple TRAMONTANE) : CA1, rançon par l'éditeur du logiciel d'entrepôt	Comptes nominatifs et authentification multifacteur sur la télémaintenance	Responsable sécurité, avec la DSI ; 22/09/2026 (année 1)	Build 8 000 € + 10 j ; run 3 000 € + 4 j par an ; 3 ans ; 9 333 € par an	V3 à V1 ; Élevé à Moyen

Lecture du tableau : la référence du risque est celle du registre ; l'échéance se donne en année 1 à 3 ; dans la colonne coût, j = jours-personnes ; build, ce qui se paie une fois ; run, ce qui se paie chaque année ; la durée est celle de l'amortissement du build ; le coût annuel est celui que l'outil calcule au taux journalier de l'instance.

Le test de la ligne lisible

Prendre une ligne du plan au hasard et la faire lire par quelqu'un qui n'a pas suivi l'étude. S'il ne peut pas dire qui a décidé quoi, pourquoi et jusqu'à quand, la ligne est à réécrire. Une décision qui a besoin de son auteur pour être comprise ne survivra pas à son auteur.

✓ Étape 2 : formaliser les acceptations (20 minutes)

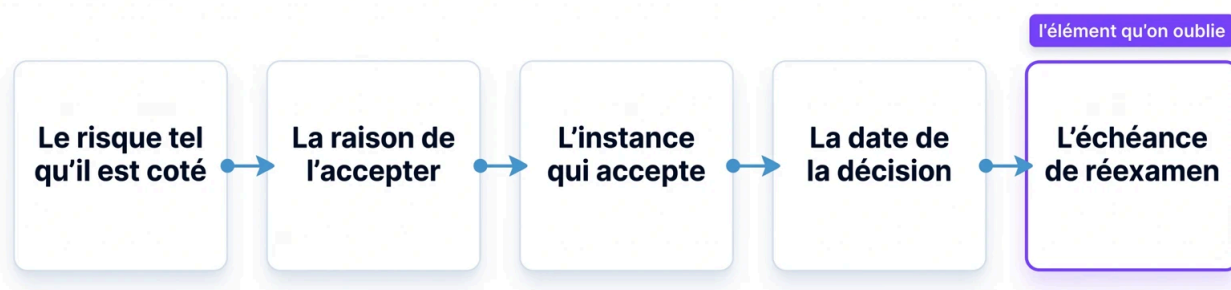
Consignes

Écrire une décision pour chaque risque accepté en l'état et pour chaque résiduel qui reste au-dessus de la ligne d'acceptation après traitement ; les deux appellent un écrit, pas le même. L'acceptation simple tient en cinq

éléments : le risque tel qu'il est coté, la raison de l'accepter, l'instance qui accepte, la date et l'échéance de réexamen. La dérogation ajoute ce qu'exige une décision plus lourde : pourquoi le traitement supplémentaire n'est pas engagé, ce qu'il faudrait pour l'engager, à quelle condition la dérogation tomberait. Vérifier l'instance : une acceptation se signe au niveau où l'appétence a été fixée, une dérogation à ce niveau ou au-dessus, jamais par un directeur de filiale sur un risque de groupe.

À produire : une fiche d'acceptation par risque accepté et une demande de dérogation par résiduel au-dessus de la ligne, chacune avec son instance signataire et son échéance de réexamen ; s'il n'y a aucune dérogation à demander, l'écrire et dire pourquoi.

Une acceptation en bonne et due forme



La phrase à ne jamais écrire

« Risque accepté par le RSSI. » Elle apparaît dans beaucoup de dossiers réels et elle est le symptôme exact que la séance 1 a appris à repérer : le RSSI prépare et propose, la direction accepte. Un RSSI qui signe l'acceptation porte seul, le jour de l'incident, une décision qu'il n'avait pas qualité pour prendre.

✓ Étape 3 : la sous-section de la note de stratégie (15 minutes)

Consignes

Ajouter à la note de stratégie sa sous-section de traitement du risque, sans réécrire les précédentes. La note reste un document unique de trois à cinq pages de texte, tableaux et annexes non comptés, dont la version de la séance N contient toutes les sous-sections de 1 à N ; rien ne se supprime, tout peut s'amender avec la phrase qui justifie l'amendement. Trois choses suffisent dans la sous-section : la position du groupe sur l'acceptabilité du risque, les décisions structurantes prises aujourd'hui, et ce qui reste ouvert avec l'échéance à laquelle ce sera tranché. Relire les sous-sections antérieures : si l'appétence de la séance 5 ne résiste pas à ce qui vient d'être coté, l'amender et dire pourquoi.

À produire : la version de la séance 7 de la note de stratégie, avec sa nouvelle sous-section et, le cas échéant, les amendements justifiés des précédentes.

Ce que la contrainte de longueur apprend

Un RSSI qui ne sait pas tenir en quelques pages ne sera pas lu. Ce n'est pas une injustice faite aux gens sérieux, c'est la condition d'exercice du métier : le temps d'attention d'un comité est court, et la sécurité concourt avec tout le reste. Le travail de réduction que la note impose est le même que celui de la séance 10, où le temps de parole sera de dix minutes.

✓ Grille d'auto-évaluation du D7

Exigence	Atteinte quand	Signe que ce n'est pas atteint
Aucun risque sans décision	Chaque ligne du registre porte une option, ou l'explication écrite de son report avec le nom de qui décidera	Des scénarios laissés en état ouvert
Dérogations motivées	Chaque résiduel au-dessus de l'appétence porte sa motivation et son instance	Un résiduel élevé sans mention particulière
Cotations cohérentes	Les niveaux cités sont ceux du D5, sans exception	Une échelle nouvelle apparue en cours de dossier
Traçabilité des mesures	Risque visé, mesure, porteur, échéance, effet attendu	Une mesure sans porteur ou sans échéance
Charge et coût annuel	Chaque mesure porte ses jours-personnes et son coût annuel lus dans l'outil, build et run distingués ; le plan porte son total en face du coût de l'inaction	Des mesures sans coût, impossibles à prioriser ni à arbitrer
Résiduels cohérents	Cotés après décision, jamais supérieurs à l'actuel	Un résiduel saisi avant les mesures
Légitimité des signatures	Acceptations et dérogations au niveau où l'appétence a été fixée	« Risque accepté par le RSSI »
Lisibilité	Chaque ligne se comprend sans son auteur	Des décisions qui appellent une explication orale

✓ Ce qui s'emporte vers la séance 8

Le dossier D7 est le matériau direct de la séance suivante, et c'est le raccord le plus important de la formation. À la séance suivante, la déclaration d'applicabilité justifie l'inclusion de chaque mesure du référentiel par un risque du D7 ou par une exigence légale ou contractuelle. Autrement dit, ce qui vient d'être décidé devient la preuve que le système de management repose sur une analyse et non sur une liste recopiée.

Vérifier donc une chose avant de rendre : que chaque mesure du plan de traitement soit formulée de façon à pouvoir être rapprochée d'une exigence du référentiel retenu en séance 3. Une mesure écrite en termes trop généraux, « renforcer la sécurité des accès », ne se rapproche de rien. La même mesure écrite en termes d'objectif, « supprimer les comptes d'administration partagés au profit de comptes nominatifs tracés », se rattache directement et se vérifie.

C'est ce fil qui rend une certification défendable : du risque coté à la mesure décidée, de la mesure décidée à l'exigence du référentiel, et de l'exigence à la preuve. Les deux premiers maillons en sont tenus aujourd'hui.



Corrigé enseignant : le D7 joué sur TRAMONTANE
(instance GØ)

— cliquer pour
révéler